

Migração para a Nuvem AWS

Documentação do MVP — Mercantis

Infraestrutura como código (Terraform) · Frontend em Docker · RDS MariaDB

TI5A — Cloud Computing · ESPM · Semestre 2026-I
Estudo de caso Mercantis / move2cloud

Sumário

1. Introdução

Este documento descreve o MVP de migração do portal de e-commerce da Mercantis para a nuvem AWS. A Mercantis opera há cerca de dez anos um portal de vendas hospedado em ambiente on-premises. Uma tempestade derrubou a energia, os no-breaks não aguentaram, e o portal saiu do ar por horas. A consultoria que avaliou o ambiente encontrou três problemas centrais: um firewall de borda sem capacidade de inspecionar requisições da aplicação, o servidor web Apache e o banco MariaDB no mesmo segmento de rede público, e nenhuma redundância para absorver picos de tráfego ou falhas de hardware.

O MVP responde a esses problemas com uma arquitetura enxuta na AWS, provisionada por Terraform. Ele entrega o caminho crítico da migração: o frontend roda em um container Docker sobre EC2, o banco passa a ser um Amazon RDS MariaDB gerenciado em sub-rede privada, e a borda ganha CloudFront, AWS WAF e AWS Shield. Sobre o diagrama-base fornecido, acrescentei controles de segurança adicionais descritos na seção 7.

Escopo. O MVP valida a arquitetura, a segurança de rede e a separação entre camadas. Ele não cobre ainda o auto scaling, o balanceador de carga e o Multi-AZ completo, reservados para a arquitetura final (seção 5). A estratégia de migração combina *replatform* (banco gerenciado no RDS) com *refactor* leve (frontend containerizado), em linha com as opções discutidas no roteiro move2cloud da disciplina.

2. O portal web da Mercantis: real vs. MVP

2.1. O portal real

O portal real da Mercantis é uma loja virtual de catálogo amplo, voltada ao mercado nacional. Os clientes navegam por categorias, pesquisam produtos, montam o carrinho, criam conta, fazem login, finalizam a compra e acompanham pedidos. A operação valoriza preço competitivo e entrega rápida, e sofre nos períodos de pico, como datas comemorativas e promoções, quando a arquitetura estática on-premises não acompanha o aumento de acessos. Os clientes distantes do data center também enfrentam lentidão, porque não há distribuição de conteúdo por regiões.

Em produção, o portal envolveria múltiplos serviços: catálogo, busca, carrinho, contas de usuário, pagamentos integrados a adquirentes, gestão de pedidos e estoque, e integrações com logística. Esses serviços conversam com um banco relacional e com armazenamento de mídia (imagens de produtos).

2.2. O que o MVP representa

O MVP reproduz a espinha dorsal dessa aplicação sem recriar todas as integrações. Uma única instância EC2 executa o container do frontend, que representa a camada web e de aplicação do portal. O Amazon RDS MariaDB substitui o banco que antes rodava no servidor dedicado on-premises, agora isolado em sub-rede privada. Um bucket S3 guarda os arquivos estáticos (imagens, CSS, JavaScript) que o CloudFront distribui com baixa latência.

A imagem Docker padrão do MVP é uma aplicação de demonstração. Para usar a loja real, basta publicar a imagem da Mercantis em um registry e apontar a variável `frontend_image`, como descreve o README. A arquitetura de rede, segurança e dados permanece a mesma.

Dimensão	Portal real (produção)	MVP (este projeto)
Camada web/app	Vários servidores atrás de balanceador, com auto scaling	Uma EC2 com container Docker
Banco de dados	MariaDB com réplicas e alta disponibilidade	RDS MariaDB single-AZ (Multi-AZ na arquitetura final)
Estáticos	CDN sobre bucket de objetos	S3 privado servido via CloudFront (OAC)
Disponibilidade	Multi-AZ, tolerante a falhas	AZ única para compute; 2 AZs já provisionadas na rede
Segurança de borda	WAF, Shield, TLS, DDoS	WAF + Shield Standard + CloudFront com HTTPS

Tabela 1. Comparação entre o portal real e o que o MVP entrega.

3. O serviço web disponibilizado

O serviço web do MVP expõe as funções típicas de uma loja virtual. A descrição abaixo cobre o que a camada de aplicação atende e como cada função usa a infraestrutura provisionada.

3.1. Funcionalidades

- Catálogo e busca: listagem de produtos por categoria e pesquisa. As imagens vêm do S3 via CloudFront; os dados de produto vêm do RDS MariaDB.
- Cadastro de usuários: criação de conta com e-mail e senha. Os registros ficam no MariaDB; as senhas devem ser armazenadas com hash forte pela aplicação.
- Login e sessão: autenticação do usuário e manutenção de sessão durante a navegação.
- Carrinho de compras: adicionar, remover e atualizar itens. O estado do carrinho é mantido pela aplicação e persistido no banco.
- Checkout e pedidos: finalização da compra e registro do pedido. Em produção, integra-se a um provedor de pagamento externo.
- Conteúdo estático: páginas, imagens, folhas de estilo e scripts entregues pelo CloudFront a partir do bucket S3, sob o prefixo /static/.

3.2. Caminho de uma requisição

O usuário acessa a URL do CloudFront. A requisição passa pelo AWS WAF, que filtra ataques comuns e aplica limite de taxa, e pelo AWS Shield, que mitiga DDoS na borda. O CloudFront encaminha o tráfego dinâmico para a EC2 do frontend e serve o conteúdo estático direto do S3. A EC2 consulta o RDS MariaDB pela porta 3306, dentro da rede privada. O usuário nunca alcança a EC2 ou o banco diretamente: o front só aceita conexões vindas do CloudFront, e o banco só aceita conexões vindas do front.

4. Diagrama da infraestrutura final (alvo)

A arquitetura final atende os SLOs definidos no roteiro move2cloud da Mercantis: disponibilidade de 99,9% ao mês, latência p95 menor ou igual a 300 ms no pico, RTO de até 1 hora e RPO de até 15 minutos. Ela distribui a aplicação por duas Availability Zones, com balanceador de carga, auto scaling e banco em Multi-AZ.

Infraestrutura Final (alvo) — Mercantis (AWS, Multi-AZ)

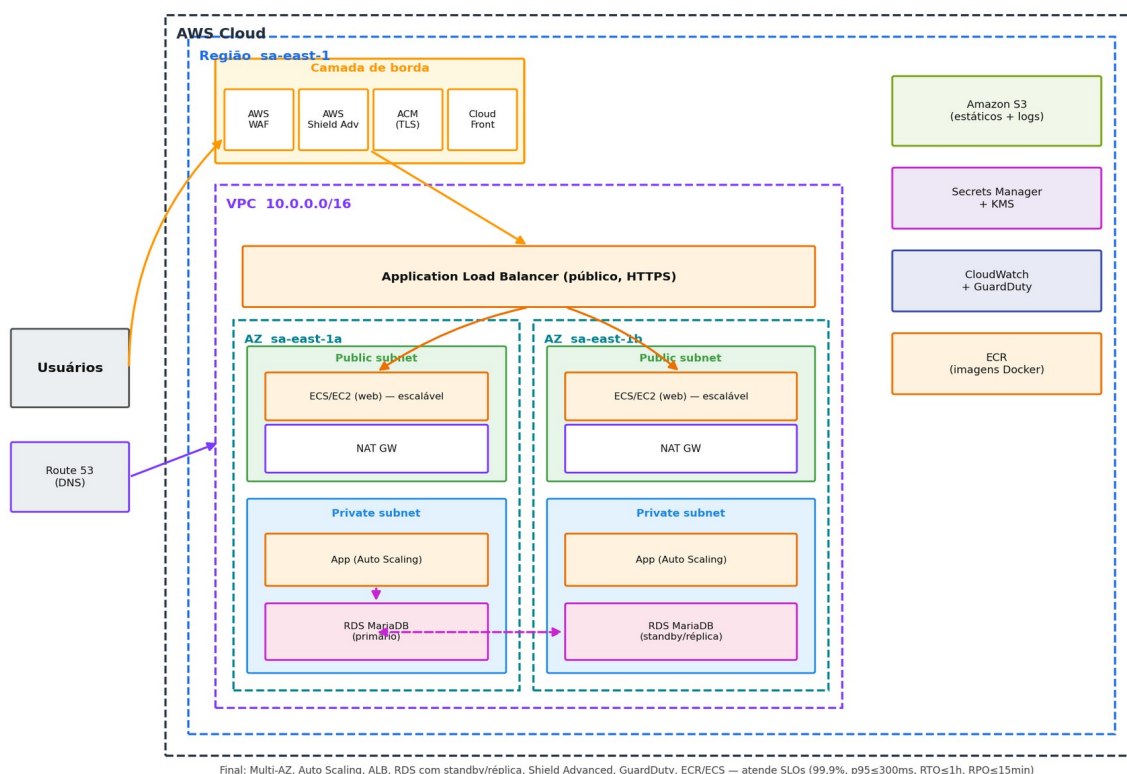


Figura 1. Infraestrutura final (alvo) em duas AZs, com ALB, auto scaling e RDS Multi-AZ.

4.1. Componentes da arquitetura final

- Route 53 para DNS e roteamento, com certificado TLS no ACM.
- CloudFront, WAF e Shield Advanced na borda, com proteção DDoS reforçada.
- Application Load Balancer público distribuindo tráfego entre as duas AZs.
- Camada de aplicação escalável (ECS ou EC2 em Auto Scaling Group) em sub-redes privadas.
- RDS MariaDB Multi-AZ, com standby em outra AZ para failover automático e réplicas de leitura.
- S3 para estáticos e logs, ECR para imagens Docker, GuardDuty e CloudWatch para detecção e observabilidade.

5. Diagrama da infraestrutura do MVP

O MVP implementa o núcleo da arquitetura final com menos componentes, para validar segurança e funcionamento a custo baixo. A rede já nasce com duas AZs, o que prepara o terreno para o Multi-AZ sem reescrever a infraestrutura.

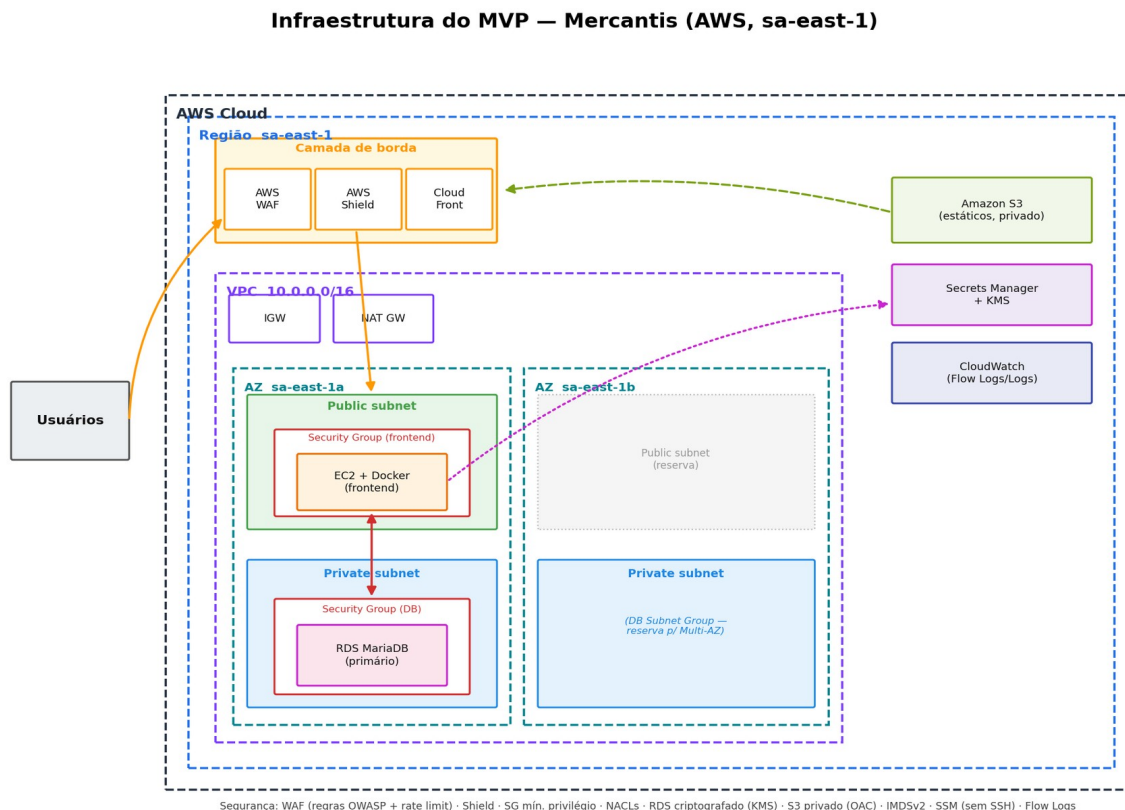


Figura 2. Infraestrutura do MVP: EC2 com Docker na sub-rede pública e RDS MariaDB na privada.

5.1. Componentes do MVP

- VPC 10.0.0.0/16 com sub-redes pública e privada em duas AZs (sa-east-1).
- EC2 com Docker na sub-rede pública, executando o container do frontend.
- RDS MariaDB na sub-rede privada, sem acesso público.
- CloudFront com AWS WAF e AWS Shield Standard na borda.
- Bucket S3 privado para estáticos, servido pelo CloudFront via Origin Access Control.
- Internet Gateway para a sub-rede pública e NAT Gateway para a saída controlada da privada.
- Secrets Manager com KMS para as credenciais do banco, e VPC Flow Logs no CloudWatch.

5.2. Decisões de arquitetura e justificativas

Decisão	Justificativa
Frontend em EC2 + Docker	Atende o requisito de container e mantém fidelidade ao ícone de EC2 do diagrama-base. Containeriza a aplicação (refactor leve) sem o custo operacional de um cluster no MVP.
Banco em RDS MariaDB gerenciado	Estratégia replatform: a AWS cuida de backup, patch e failover. Resolve o servidor de banco on-premises exposto e sem redundância.
Região sa-east-1 (São Paulo)	Menor latência para clientes no Brasil, coerente com um e-commerce nacional.
Banco em sub-rede privada	Elimina o problema do banco em segmento público on-premises e bloqueia movimento lateral entre web e dados.
CloudFront + WAF + Shield	Distribui estáticos por borda (resolve a lentidão regional) e inspeciona requisições da aplicação (resolve o firmware de borda sem filtragem).
Duas AZs na rede desde o MVP	Exigência do DB Subnet Group e base para o Multi-AZ da arquitetura final, sem retrabalho.

Tabela 2. Principais decisões técnicas do MVP e suas justificativas.

6. Detalhes técnicos: segurança do MVP

A segurança do MVP segue defesa em camadas: borda, rede, instância e dados. Cada camada aplica privilégio mínimo. Esta seção detalha as regras dos Security Groups e os demais controles, incluindo os que adicionei sobre o diagrama-base.

6.1. Security Groups

Os Security Groups são o firewall stateful em nível de instância. Duas regras de ouro orientam o MVP: o frontend só aceita tráfego do CloudFront, e o banco só aceita tráfego do frontend. Em vez de liberar a porta 80 para a internet inteira, a regra de entrada do frontend usa a prefix list gerenciada do CloudFront (com.amazonaws.global.cloudfront.origin-facing), de modo que somente os IPs de origem do CloudFront alcançam a EC2.

SG do frontend (EC2)

Direção	Protocolo/Porta	Origem / Destino	Finalidade
Entrada	TCP 80	Prefix list do CloudFront	HTTP somente do CloudFront
Entrada	TCP 443	Prefix list do CloudFront	HTTPS somente do CloudFront
Saída	Todos	0.0.0.0/0	Baixar imagem Docker e patches

Tabela 3. Regras do Security Group do frontend. Não há porta 22 (SSH).

SG do banco de dados (RDS MariaDB)

Direção	Protocolo/Porta	Origem / Destino	Finalidade
Entrada	TCP 3306	SG do frontend (referência)	MariaDB apenas a partir do frontend
Saída	Todos	0.0.0.0/0	Manutenção gerenciada pelo RDS

Tabela 4. Regras do Security Group do banco. A origem é o SG do front, não um CIDR.

Referenciar o Security Group de origem, em vez de um CIDR, garante que apenas as instâncias do frontend conversem com o banco, mesmo que os endereços mudem. Essa é a barreira que faltava no ambiente on-premises, onde web e banco dividiam o mesmo segmento público.

6.2. Controles adicionais de segurança

Sobre o diagrama-base, acrescentei os controles abaixo para cobrir rede, instância, dados e auditoria.

Controle	O que faz	Camada
Network ACLs	Filtro stateless por sub-rede. A NACL privada só aceita 3306 de dentro da VPC e portas efêmeras; bloqueia entrada direta da internet.	Rede
NAT Gateway	Dá saída à sub-rede privada sem aceitar conexões de entrada. O banco nunca fica exposto.	Rede

Controle	O que faz	Camada
WAF com regras gerenciadas	Bloqueia ataques comuns (OWASP), IPs de má reputação e aplica rate limit de 2000 req por IP.	Borda
HTTPS obrigatório (TLS)	CloudFront redireciona todo acesso para HTTPS, atendendo o SLO de 100% do tráfego com TLS.	Borda
RDS criptografado (KMS)	Armazenamento do banco cifrado em repouso com chave KMS dedicada e rotação habilitada.	Dados
S3 privado com OAC	Bucket sem acesso público, criptografado e versionado; só o CloudFront lê os objetos.	Dados
Secrets Manager	A senha do banco é gerada aleatoriamente e guardada em cofre, nunca em texto plano no código.	Dados
IAM com privilégio mínimo	A EC2 só pode ler o bucket de estáticos e o segredo do banco, via perfil de instância.	Instância
SSM Session Manager	Acesso administrativo à EC2 sem abrir a porta 22. Elimina a superfície de ataque do SSH.	Instância
IMDSv2 obrigatório	Protege as credenciais da instância contra roubo por SSRF.	Instância
Disco EBS criptografado	Volume raiz da EC2 cifrado em repouso.	Instância
VPC Flow Logs	Registra todo o tráfego de rede no CloudWatch para auditoria e investigação de incidentes.	Auditoria

Tabela 5. Controles de segurança adicionados ao MVP, por camada.

Mapeamento com o checklist de Dia 1 do move2cloud. O roteiro da disciplina exige seis cuidados no primeiro dia: contas com MFA, WAF, HTTPS em todo o tráfego, dados criptografados em repouso e em trânsito, segredos em cofre e logs centralizados. O MVP cobre WAF, HTTPS, criptografia (KMS no RDS e SSE no S3), Secrets Manager e Flow Logs. O MFA fica no nível da conta AWS e do usuário IAM que executa o Terraform, conforme orienta o README.

7. Conclusão

O MVP resolve os três problemas que a consultoria apontou no ambiente on-premises da Mercantis. A indisponibilidade por falta de energia e a fragilidade física dão lugar à infraestrutura gerenciada da AWS, com backups automáticos e duas AZs já provisionadas na rede. O banco sai do segmento público e passa a viver em sub-rede privada, acessível apenas pelo frontend, o que fecha o caminho de movimento lateral. A borda ganha WAF, Shield e CloudFront, que inspecionam requisições, mitigam DDoS e distribuem conteúdo estático por regiões, atacando tanto a falta de filtragem quanto a lentidão nos picos.

O Terraform entrega tudo isso como código reproduzível: um terraform apply sobe a infraestrutura, e um terraform destroy a remove. A separação em arquivos por domínio (rede, segurança, compute, dados, borda) facilita a evolução para a arquitetura final, que acrescenta balanceador, auto scaling e Multi-AZ para cumprir integralmente os SLOs de 99,9% de disponibilidade, p95 de 300 ms, RTO de 1 hora e RPO de 15 minutos.

O próximo passo natural é publicar a imagem real do portal no ECR, ativar o Multi-AZ no RDS e introduzir o Application Load Balancer com auto scaling. A base de segurança e rede do MVP sustenta essa transição sem retrabalho.

Referências

- Estudo de caso Mercantis (TI5A — Cloud Computing, ESPM 2026-I). estudo-de-caso.md.
- Roteiro Move2Cloud da Mercantis: metas, SLOs, estratégias de migração e checklist de Dia 1. mercantis-move2cloud.md.
- AWS Well-Architected Framework: pilar de segurança. conceitos-gerais-aws.md.
- Web Application Hosting in the AWS Cloud (whitepaper de referência). web-application-hosting-best-practices.md.